ArchFlow — Security Review

Дата: 31 марта 2026 **Проект:** ArchFlow (archflow.ru) **Стек:** Next.js 15 + Supabase (Beget Cloud) + Netlify **Ревизия:** commit HEAD, ветка main

---

Содержание

1. Сводка
2. КРИТИЧНО
3. ВАЖНО
4. РЕКОМЕНДАЦИЯ
5. Пройденные проверки
6. RLS-матрица
7. Приоритет исправлений

Сводка

Уровень	Кол-во
КРИТИЧНО	1
ВАЖНО	7
РЕКОМЕНДАЦИЯ	6
ПРОЙДЕНО	8

Главная угроза: Эндпоинт `/api/auth/signup` позволяет любому зарегистрировать аккаунт с ролью `designer` (полный доступ). Исправить немедленно.

КРИТИЧНО

C-1. Signup — privilege escalation через поле `role`

КРИТИЧНО

Файл: `src/app/api/auth/signup/route.ts`, строки 17, 60-68

Проблема: Эндпоинт принимает `role` из тела запроса и записывает в `profiles` без валидации. Любой может вызвать API напрямую и получить максимальные привилегии.

```
POST /api/auth/signup
{ "email": "attacker@evil.com", "password": "123456", "role": "designer" }
```

Код:

```
const { email, password, full_name, role } = body;
// ... нет валидации role ...
if (data.user && (role || full_name)) {
  await supabaseAdmin
    .from("profiles")
    .update({
      ...(full_name && { full_name }),
      ...(role && { role }),         // <-- любое значение
    })
    .eq("id", data.user.id);
}
```

Фикс:

```
const ALLOWED_ROLES = ['designer', 'client'];
if (role && !ALLOWED_ROLES.includes(role)) {
  return NextResponse.json(
    { error: 'Недопустимая роль' }, { status: 400 }
  );
}
```

ВАЖНО

I-1. API /api/push/send — нет аутентификации

ВАЖНО

Файл: `src/app/api/push/send/route.ts`, строка 23

Проблема: Эндпоинт принимает `senderUserId` из body без проверки JWT/сессии. Любой, кто знает `projectId`, может рассылать push-уведомления от имени любого пользователя.

Фикс: Извлекать JWT из `Authorization` header, проверять через `supabase.auth.getUser(token)`, сравнивать `senderUserId === session.user.id`.

I-2. API /api/invite/send — open email relay

ВАЖНО

Файл: `src/app/api/invite/send/route.ts`

Проблема: Нет проверки авторизации. Любой может отправить email от имени `hello@archflow.ru` на произвольный адрес с произвольным `inviteUrl`. Вектор для фишинга.

Фикс: Проверять JWT + permission `canInviteMembers` для проекта.

I-3. Нет rate limiting ни на одном API-эндпоинте

ВАЖНО

Файлы: все 4 route-файла в `src/app/api/`

Проблема:

- `/api/auth/signup` — массовое создание аккаунтов
- `/api/feedback` — спам в Telegram
- `/api/invite/send` — массовые рассылки email
- `/api/push/send` — спам push-уведомлений

Фикс: Rate limiting на уровне Netlify или middleware. Приоритет: signup и invite.

I-4. profiles INSERT — `WITH CHECK (true)`

ВАЖНО

Файл: `supabase/migrations/008_fix_signup_trigger.sql`, строка 32

```
CREATE POLICY "Allow trigger insert profiles"
  ON profiles FOR INSERT WITH CHECK (true);
```

Проблема: Любой аутентифицированный пользователь может вставить произвольные строки в таблицу `profiles`.

Фикс: `WITH CHECK (auth.uid() = id)` — можно создать только свой профиль.

I-5. project_invitations UPDATE — `USING (true)`

ВАЖНО

Файл: `supabase/migrations/007_project_invitations.sql`, строка 32

```
CREATE POLICY "Auth users can update invitations"
  ON project_invitations FOR UPDATE USING (true);
```

Проблема: Любой аутентифицированный пользователь может изменить любой invite — подменить `role`, `access_level`, `token`.

Фикс: `USING (created_by = auth.uid())`.

I-6. Storage buckets — public без DELETE-политик

ВАЖНО

Файлы: `migrations/004_storage_and_rpc.sql`, `migrations/006_documents_bucket.sql`

Проблема: Бакеты `photos` и `documents` помечены `public = true`. URL файлов доступны без аутентификации. DELETE-политики отсутствуют.

Фикс: Сделать бакеты `public = false`, отдавать через signed URLs. Добавить DELETE-политики для владельцев.

I-7. HTML-инъекция в email-шаблонах

ВАЖНО

Файл: `src/app/lib/mailer.ts`, строки ~75, 127

```
`<p>Привет, ${name}!</p>`
`<a href="${inviteUrl}">`
```

Проблема: Пользовательские данные (`name`, `projectName`, `inviteUrl`) вставляются в HTML без экранирования. Вектор: вредоносное имя `<img src=x onerror=...>` или `inviteUrl = "javascript:..."`.

Фикс: HTML-encode все переменные. Для URL — проверять `url.startsWith('https://')`.

РЕКОМЕНДАЦИЯ

R-1. Demo-креды в публичных файлах репозитория

РЕКОМЕНДАЦИЯ

Файлы: `CLAUDE.md:138`, `PROJECT_CONTEXT.md:105–106`, `README.md:17`

Реальные пароли demo-аккаунтов закоммичены в репо. Если GitHub-репо публичный — ротировать пароли немедленно.

R-2. Нет security headers

РЕКОМЕНДАЦИЯ

Файл: `netlify.toml`

Нет CSP, X-Frame-Options, X-Content-Type-Options.

Фикс: Добавить в `netlify.toml`:

```
[[headers]]
  for = "/*"
  [headers.values]
    X-Frame-Options = "DENY"
    X-Content-Type-Options = "nosniff"
    Referrer-Policy = "strict-origin-when-cross-origin"
```

R-3. Слабая парольная политика

РЕКОМЕНДАЦИЯ

Файл: `src/app/api/auth/signup/route.ts:26`

Минимум 6 символов, без требований к сложности. Рекомендуется: минимум 8 символов, хотя бы 1 цифра и 1 буква.

R-4. lookup_profile_by_email — email enumeration

РЕКОМЕНДАЦИЯ

Файл: `migrations/004_storage_and_rpc.sql:27`

`SECURITY DEFINER` функция позволяет любому аутентифицированному пользователю проверить наличие email в системе и получить полное имя.

R-5. Pending invites видны всем аутентифицированным

РЕКОМЕНДАЦИЯ

Файл: `migrations/012_rbac_schema.sql:87`

Политика `project_members SELECT` с `invite_token IS NOT NULL AND status = 'pending'` позволяет видеть все pending invite-токены. Можно принять чужой invite.

Фикс: Добавить `AND invite_email = auth.email()`.

R-6. Пропущены RLS-политики на ряде таблиц

РЕКОМЕНДАЦИЯ

Таблица	Пропущено
`photo_records`	DELETE
`project_access_settings`	DELETE
`remark_comments`	UPDATE, DELETE
`contractor_tasks`	DELETE
`chat_reads`	DELETE
`push_subscriptions`	UPDATE
`design_files`	UPDATE
`design_file_comments`	UPDATE

Пройденные проверки

#	Проверка	Результат
1	`service_role_key` не в клиентском коде	ПРОЙДЕНО Только в серверных route через `process.env` (без `NEXT_PUBLIC_`)
2	`NEXT_PUBLIC_` переменные безопасны	ПРОЙДЕНО URL, anon key, VAPID public, YM ID
3	`.env.local` в `.gitignore`	ПРОЙДЕНО Не закоммичен

4	`.env` не в git-истории	ПРОЙДЕНО
5	JWT refresh / session handling	ПРОЙДЕНО Корректная обработка expiry, refresh, signOut
6	XSS через `dangerouslySetInnerHTML`	ПРОЙДЕНО Только статический скрипт для темы
7	SQL injection	ПРОЙДЕНО Supabase JS — параметризованные запросы
8	Sanitize на вводе	ПРОЙДЕНО `sanitize()` во всех query-функциях

RLS-матрица

Полное покрытие Row Level Security по всем таблицам проекта:

Таблица	RLS	SELECT	INSERT	UPDATE	DELETE
profiles	ON	OK	**OPEN**	OK (own)	—
projects	ON	OK	OK	OK	OK
project_members	ON	OK	OK (owner)	OK	OK (owner)
stages	ON	OK	OK (owner)	OK (owner)	OK (owner)
visits	ON	OK	OK	OK	OK
photo_records	ON	OK	OK	OK	—
invoices	ON	OK	OK (owner)	OK (owner)	OK (owner)
documents	ON	OK	OK	OK	OK
supply_items	ON	OK	OK (owner)	OK (owner)	OK (owner)
contract_payments	ON	OK	OK (owner)	OK (owner)	OK (owner)
project_invitations	ON	OK	OK	**OPEN**	—
tasks	ON	OK	OK	OK	OK
project_access_settings	ON	OK	OK (owner)	OK (owner)	—
visit_reports	ON	OK	OK	OK	OK
visit_remarks	ON	OK	OK	OK	OK
remark_comments	ON	OK	OK	—	—

contractor_tasks	ON	OK	OK	OK	—
chat_messages	ON	OK	OK	OK (own)	OK (own)
chat_reads	ON	OK (own)	OK (own)	OK (own)	—
push_subscriptions	ON	OK (own)	OK (own)	—	OK (own)
design_files	ON	OK	OK	—	OK
design_file_comments	ON	OK	OK	—	OK

OK = политика есть и корректна | **OPEN** = политика слишком разрешительная | **—** = политика отсутствует

Приоритет исправлений

#	Уязвимость	Приоритет	Трудоёмкость
C-1	Signup role escalation	**P0 — немедленно**	15 мин
I-5	Invitations UPDATE open	**P1 — сегодня**	10 мин
I-2	Invite send — no auth	**P1 — сегодня**	30 мин
I-1	Push send — no auth	**P1 — сегодня**	30 мин
I-4	Profiles INSERT open	**P2 — эта неделя**	10 мин
I-7	Email HTML injection	**P2 — эта неделя**	20 мин
I-3	No rate limiting	**P2 — эта неделя**	1 час
I-6	Storage public buckets	**P3 — бэклог**	2 часа
R-1..R-6	Рекомендации	**P3 — бэклог**	разное